

Security, Privacy & DPDP Readiness

Professional engineering test report

CONDITIONAL TECHNICAL READINESS

12/12	21/21	0
security controls	Expo checks	dependency vulnerabilities

Assessment date	22 September 2026
Branch	dev
Commit	d51d973
Scope	Expo application, Supabase controls, AI and payment paths, consent, repository history, generated build and safe live probes

No known critical or high-severity vulnerability was found in the remediated source and generated build. The hosted security controls still require deployment and authenticated retesting before production assurance or a DPDP compliance claim.

Executive assurance statement

Within the remediated **source and generated-build scope**, the assessment found no unresolved critical or high-severity security finding. Twelve security regression controls passed, TypeScript and all Edge Functions type-checked, Expo Doctor passed 21 of 21 checks, the production web export completed, and the production dependency audit reported zero known vulnerabilities across 527 production dependencies.

No evidence of patient personal information or privileged secrets was found in the repository worktree, Git history, or generated executable bundle. Safe anonymous probes returned no patient rows, and three sensitive AI endpoints rejected unauthenticated requests. These results support the statement: **no patient-data exposure was detected in the tested paths**. They do not prove that disclosure is impossible in every device, provider, log, backup, administrator workflow, or future version.

Consent controls are present in the remediated source. Personalisation is optional during onboarding; AI access to stored health context and doctor sharing default to off; changes are recorded through append-only, server-timestamped consent events bound to the exact consent document hash; and the adult-only boundary is enforced in both the app and database migration.

The source is materially aligned with DPDP technical requirements, but the deployed system cannot yet be certified or represented as fully DPDP compliant. The hardened database migration and Edge Functions have not been deployed to the configured backend, operational privacy evidence remains outstanding, and the product document itself identifies legal and organisational details that require confirmation.

Overall result

Area	Result	Assurance supported
Remediated source security	Pass	No known critical or high-severity source finding in the completed review
Production dependencies	Pass	0 known vulnerabilities reported by <code>npm audit --omit=dev</code>
Repository secret exposure	Pass	No high-confidence secret or configured sensitive value found in the worktree or Git history
Patient PII exposure	Pass with scope limits	No patient identifiers found in repository text or returned by anonymous backend probes
Anonymisation	Not applicable to current product output	No anonymised user dataset is published; Aadhaar/PAN fingerprints are pseudonymisation, not anonymisation
Consent controls	Pass in source; deployment pending	Granular defaults, withdrawal controls, exact document evidence, and server timestamps are implemented
Hosted backend	Release gate open	Anonymous access controls passed; hosted Edge Functions still expose permissive CORS because hardened functions are not deployed
DPDP readiness	Conditional	Technical alignment is substantial; deployment, operational evidence, processor controls, and legal publication details remain open

Testing performed

Application and server-function verification

Test	Result
Security regression suite	Pass - 12/12 controls
TypeScript compilation with no output	Pass
Deno type-check of all 8 Edge Functions	Pass
Expo Doctor	Pass - 21/21 checks
Production Expo web export	Pass
Production dependency audit	Pass - 0 vulnerabilities across 527 production dependencies
Git whitespace and patch integrity check	Pass
Consent PDF generation and SHA-256 binding	Pass - 4641d907ce0e3eaf2ac34d763bb69244ed58076a2c1657f288777041ea17ffff
Consent PDF visual review	Pass - all 15 pages rendered; no clipping, overlap, missing text, or broken table observed

Secret and personal-information review

The worktree scanner checked text source and generated artifacts for private-key blocks, common provider token formats, configured secret values from the ignored local environment file, and Aadhaar- and PAN-shaped values. Git history was separately scanned without printing possible values. Two numeric matches in historical minified asset filenames were manually triaged as parts of content hashes, not identifiers.

Test	Result
High-confidence secret patterns in worktree	Pass - none found
Exact configured sensitive values in repository text	Pass - none found
High-confidence secret patterns and exact configured values in Git history	Pass - none found
Sensitive environment files tracked by Git	Pass - none tracked
Aadhaar/PAN values in current repository text	Pass - none found
Aadhaar/PAN values in Git history	Pass after manual triage - no identifier value found
Public professional data	Review item - 3 practitioner names, biographies, and portraits are deliberately bundled for the public doctor catalogue; publication permission must be documented

Safe live-backend probes

The following tests were read-only or unauthenticated. No account, order, appointment, payment, upload, or patient record was created or changed.

Probe	Result
Anonymous profiles read	Pass - HTTP 200, 0 rows
Anonymous appointments read	Pass - HTTP 401
Anonymous shop_orders read	Pass - HTTP 200, 0 rows
Anonymous payment_transactions read	Pass - HTTP 401
Unauthenticated ai-chat call	Pass - HTTP 401
Unauthenticated current-health-chat call	Pass - HTTP 401
Unauthenticated scan-food-meal call	Pass - HTTP 401

Probe	Result
Untrusted-origin preflight for the three functions	Fail on hosted backend - the origin is currently allowed

The preflight result confirms that the configured backend is running the older functions. The source replaces wildcard CORS with an allowlist, but that protection becomes active only after function deployment.

Security controls implemented

- Patient roles can no longer create paid appointments or orders directly. Server-side fulfilment owns the final write.
- Payment fulfilment uses a locked, atomic, idempotent database transaction and recalculates authoritative values.
- Clinical notes require a verified practitioner assigned to the appointment and create immutable audit entries.
- AI and payment paths have per-user quotas.
- Native sessions use chunked operating-system protected SecureStore storage. Medical handoff text and local order or appointment copies are no longer persisted in AsyncStorage.
- Doctor applications require authentication and owned private uploads. Raw Aadhaar and PAN values are not retained after the migration; keyed HMAC fingerprints and last-four values support duplicate detection.
- Browser CORS uses an explicit origin allowlist in source, and public responses no longer expose detailed operational errors.
- The SDK 57 dependency set is current according to Expo Doctor. A narrow uuid 11.1.1 override resolves the current transitive advisory while preserving SDK validation and build success.

Personal information and anonymisation assessment

No patient data is intentionally included in the repository. The source includes field names, validation patterns, sample placeholders, and a business support email; these are not patient records. Anonymous database probes returned no patient rows in the tested tables.

Ayurnidaan does not currently publish, sell, or disclose an anonymised user dataset in the reviewed code. There is therefore no anonymisation transform whose re-identification resistance can be certified. The keyed fingerprints for doctor government identifiers are **pseudonymous duplicate-detection values**: they reduce exposure but remain linked to an application record and must not be described as anonymous data.

The repository deliberately contains three practitioner public profiles and portrait files. This is an intended product disclosure rather than a technical leak only if Ayurnidaan has valid publication permission and the claims are accurate. That evidence was not present in the repository and is a release-owner action.

The review did not have access to infrastructure logs, production backups, support mailboxes, Google, Razorpay, OpenRouter or downstream model-provider records. Contractual retention, training-use restrictions, deletion, breach notification, and subprocessor controls must be verified separately.

Consent-control assessment

The remediated design separates contractual acceptance from optional processing choices:

- users must scroll through the 15-page Terms, Privacy Notice and Consent document before controls unlock;
- Terms acceptance is required, while personalisation is a separate optional checkbox;
- AI access to stored Prakriti, Vikriti, symptoms, age, height, and weight defaults to off and is checked before those records are fetched;
- doctor sharing defaults to off;
- privacy-setting changes are made through a server function and appended to consent history with a server timestamp;
- each consent event records the user, action, channel, document version, and exact SHA-256;
- users can withdraw supported optional settings from the Privacy and consent screen;
- onboarding and profile editing reject users below 18, and the database trigger prevents direct API bypass.

Deployment is required before the server-side audit and enforcement controls are active. Account deletion exists, but end-to-end erasure from processors, logs, backups, and legally retained records was not demonstrated.

DPDP readiness conclusion

This review uses the official [Digital Personal Data Protection Act, 2023](#), the final [Digital Personal Data Protection Rules, 2025](#), and the official [commencement notification G.S.R. 843\(E\)](#).

As of 22 September 2026, the main operational provisions in sections 3-17 of the Act and Rules 3 and 5-16 are scheduled to commence on 13 May 2027. Section 6(9), section 27(1)(d), and Rule 4 are scheduled for 13 November 2026. Phased commencement does not create a government certification process, and this engineering review is not a legal opinion.

DPDP control area	Current evidence	Status
Clear, itemised notice and specified purposes	Versioned in-app 15-page notice with categories, purposes, recipients, rights, retention targets, AI and cross-border disclosures	Implemented in source
Freely given and withdrawable consent	Optional personalisation; AI and doctor-sharing defaults off; settings can be withdrawn; append-only evidence	Implemented in source; deployment pending
Reasonable security safeguards	RLS, private buckets, least privilege, secure local session storage, atomic payment, quotas, secret controls	Implemented in source; deployment and dynamic role testing pending
Children	Adult-only service boundary in UI and database; no child flow	Implemented in source
Access, correction and erasure	Profile correction and account deletion exist; access/nomination/sharing-summary requests rely on email	Partially implemented; operating procedure and evidence required
Grievance redressal	Business email and grievance text are published	Incomplete - officer name, registered office, response timeline, ownership and records required
Retention and processor erasure	Intended schedule documented	Incomplete - automated enforcement, backup handling, legal holds and processor deletion evidence required
Personal data breach response	Notice describes response obligations	Incomplete - approved incident plan, contacts, exercises and notification evidence required
Processor and cross-border governance	Recipient categories disclosed	Incomplete - contracts, data locations, retention, training-use restrictions, subprocessors and deletion controls require verification
Public practitioner data	Public catalogue is explicit in product	Incomplete - publication consent and accuracy evidence are not in the repository

DPDP status: conditional technical readiness. The evidence does not support an unconditional statement that the deployed system is DPDP compliant.

Required release gates

1. Apply `20260922090000_security_hardening.sql` to a dedicated test project, deploy all eight functions together, configure exact allowed web origins, and rerun the live suite.
2. Execute the authenticated role matrix with Patient A, Patient B, assigned doctor, unrelated doctor, unverified doctor, and administrator identities.
3. Confirm direct patient appointment/order writes fail and concurrent Razorpay test verification creates exactly one resource.
4. Test signed Android and iOS builds for SecureStore persistence, logout and account switching, deep links, private uploads, network transport, backup behavior, and release-artifact reverse engineering.
5. Run account deletion through database, storage, logs, backups, OpenRouter/model providers, authentication providers, and support systems; retain evidence of results and lawful exceptions.
6. Approve the retention schedule, incident-response process, rights-request procedure, processor register, cross-border assessment, grievance timeline, and practitioner-publication permissions.
7. Insert and publish the confirmed grievance officer name and registered-office address, and obtain Indian legal counsel review of the production notice and operating procedures.

Statements that may be used

The completed evidence supports the following wording:

No known critical or high-severity vulnerability was found in the remediating source and generated build under the tests completed on 22 September 2026. The production dependency audit reported zero known vulnerabilities. No patient personal-data exposure was detected in repository, Git-history, generated-bundle, or safe anonymous-backend tests. Granular consent controls are implemented in source.

The evidence does not support “there are no vulnerabilities,” “personal information cannot leak anywhere,” “anonymisation is certified,” or “the deployed system is DPDP compliant.” Those statements exceed the tested scope and the current deployment and operational evidence.